

**SIMATS ENGINEERING
ASSESSMENT TOOL 3**

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1436

COURSE OUTCOME COVERED

***CO1:** Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.*

QUESTIONS: 01

Total Marks:100

Annexure A

ASSIGNMENT

Code of Conduct:

*I **Yoga Madha A/192425058** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:



S.No.	Assessment Criterion	Excellent - 4	Good -3	Satisfactory -2	Needs Improvement -1	Marks
1	Understanding of the Scenario - 10	Clearly identifies all stakeholders, actions, risks, and security concerns presented in the scenario.	Identifies most major elements with minor omissions.	Identifies only the basic elements of the scenario.	Misinterprets the scenario or misses important issues.	
2	Application of Ethical Hacking Principles -20	Accurately applies authorization, scope, privacy, confidentiality, integrity, and professional responsibility.	Applies most ethical hacking principles correctly.	Demonstrates basic understanding but provides limited application.	Ethical principles are incorrectly applied or not discussed.	
3	Legal and Ethical Analysis - 30	Clearly distinguishes legal, illegal, ethical, and unethical actions with strong justification.	Identifies most legal and ethical issues with reasonable explanation.	Provides a general discussion with limited justification.	Legal and ethical issues are unclear, inaccurate, or missing.	
4	Recommended Course of Action -20	Proposes a practical, responsible, legally appropriate, and well-justified solution.	Proposes an appropriate solution with minor gaps.	Provides a basic solution with limited explanation.	Suggests an inappropriate, unsafe, or unsupported action.	
5	Critical Thinking and Presentation-20	Response is logical, original, well-organized, professionally written, and supported with suitable examples.	Response is clear and organized with minor weaknesses.	Response is understandable but lacks depth or examples.	Response is unclear, poorly organized, or unsupported.	
					Total	

ASSIGNMENT QUESTIONS

1. Responsible Disclosure and Academic Publication

A researcher discovers a new attack technique and wishes to publish it in an academic conference. The technique affects several widely used software systems for which patches are not yet available.

Develop a coordinated publication plan. Consider vendor notification, peer review, remediation time, anonymization, and public interest.

Answer:

1. Understanding of the Scenario

Main Stakeholders

- **Security Researcher** – discovers and validates the attack.
- **Software Vendors** – responsible for affected products and patches.
- **Academic Conference/Reviewers** – evaluate the research.
- **Users/Organizations** – may be exposed to the vulnerability.
- **Security Community** – benefits from technical knowledge.
- **Attackers** – could misuse publicly available attack details.
- **CERT/CSIRT or Coordinating Authority** – can assist with coordinated disclosure.

Main Risks

1. Attackers may exploit the technique before patches are available.
2. Full technical details may increase the attacker's capability.
3. Vendors may need sufficient time to investigate and fix the issue.
4. Delaying publication too long may reduce academic value.
5. Publishing sensitive information may expose users and organizations.
6. The researcher may face legal or ethical problems if testing was unauthorized.

2. Ethical Hacking Principles Applied

The researcher should apply the following principles:

Principle	Application
Authorization	Test only systems for which permission exists.
Scope	Clearly define affected systems and testing boundaries.
Privacy	Do not collect or publish unnecessary personal data.
Confidentiality	Keep vulnerability details confidential during remediation.
Integrity	Preserve accurate evidence and research results.
Professional Responsibility	Protect users while contributing useful academic knowledge.
Minimize Harm	Avoid releasing information that makes exploitation easier.
Transparency	Communicate honestly with vendors and conference organizers.

3. Legal and Ethical Analysis

Legal Actions

The researcher should:

- Obtain authorization before testing.
- Respect software licenses and applicable laws.

- Avoid accessing unrelated systems or user information.
- Maintain evidence of authorized research.
- Follow the conference's research and disclosure policies.
- Use appropriate legal channels for vendor communication.

Potentially Illegal Actions

The following should be avoided:

- Testing systems without authorization.
- Accessing private user information.
- Modifying or destroying production data.
- Deploying the attack against real users.
- Selling the vulnerability to malicious parties.
- Publishing stolen credentials or private information.

Ethical Issue

There is a conflict between:

Public Interest

→ Researchers need to share knowledge so systems can become safer.

User Safety

→ Immediate publication could allow attackers to exploit unpatched systems.

Therefore, the researcher should choose **coordinated disclosure followed by controlled academic publication**.

4. Recommended Coordinated Publication Plan

Step 1 – Verify the Research

The researcher should reproduce the attack in a **controlled and authorized environment**.

Record:

- Affected software versions
- Attack conditions
- Security impact
- Evidence
- Possible mitigations

Do not test randomly on public systems.

Step 2 – Identify Vendors

Determine all affected software vendors and their appropriate security-contact channels.

Prepare a confidential report containing:

- Vulnerability description
- Affected versions
- Severity/impact
- Evidence of the issue
- Safe reproduction information
- Suggested mitigation
- Researcher's contact information

Step 3 – Notify Vendors Privately

Send the report to vendors **before public disclosure**.

The researcher should request acknowledgment and establish a communication channel for coordinated remediation.

Step 4 – Allow Remediation Time

Give vendors a **reasonable and mutually agreed remediation period**.

During this period:

- Do not publicly disclose exploit details.
- Answer vendor questions.
- Help validate patches.
- Monitor whether the issue affects additional products.

If multiple vendors are affected, coordinate disclosure dates where practical.

Step 5 – Contact the Conference

Inform the academic conference that the research involves an **unpatched security issue**.

The paper can be submitted for peer review, but sensitive technical details should be handled confidentially according to the conference's policies.

If necessary, request:

- Confidential handling
- Delayed publication
- Controlled supplementary material
- Redaction of dangerous exploit details

Step 6 – Anonymize Sensitive Information

The paper should not contain:

- Real user information
- Credentials
- Private logs
- IP addresses unnecessarily identifying victims
- Confidential vendor information
- Unnecessary exploit code
- Information that directly enables mass exploitation

Use terms such as:

Vendor A, System B, and Product C

where appropriate.

Step 7 – Prepare a Safe Academic Paper

The paper should emphasize:

- The research problem
- Attack concept
- Security impact
- Experimental methodology
- Evaluation
- Defensive implications
- Mitigation techniques
- Lessons for developers and researchers

The researcher should provide **enough information for academic understanding without unnecessarily providing a ready-to-use weapon**.

Step 8 – Coordinate Public Disclosure

After patches or effective mitigations are available, publish the research according to the agreed disclosure schedule.

The publication should include:

- Affected versions
- Vendor acknowledgments, where appropriate

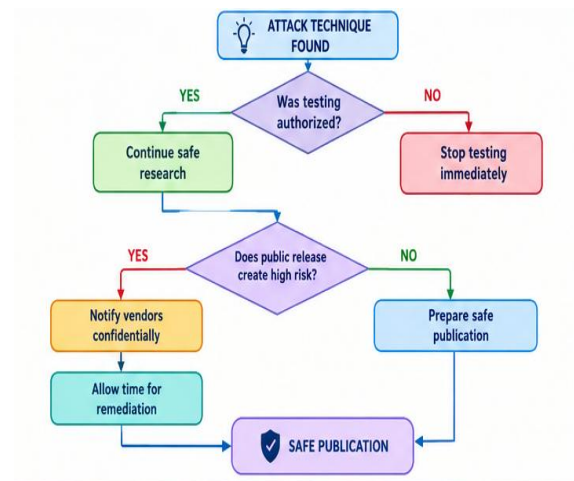
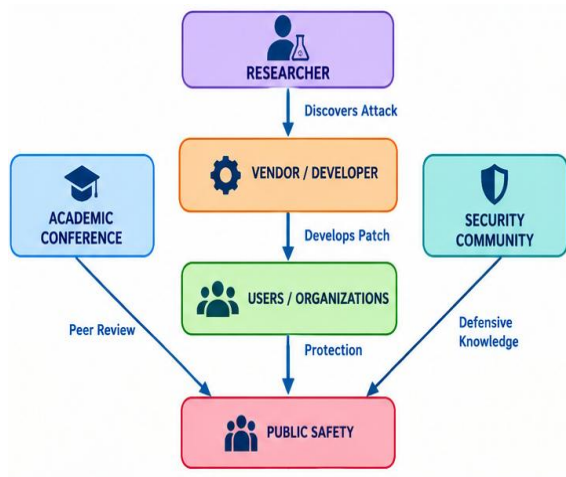
- Patch/mitigation information
- Responsible disclosure timeline
- Security recommendations

Step 9 – Post-Publication Monitoring

After publication:

- Monitor newly discovered affected systems.
- Respond to responsible questions.
- Inform vendors about newly identified impacts.
- Correct mistakes in the paper if necessary.

5. Publication Timeline



6. Responsible Disclosure Decision Diagram



7. Balancing Public Interest and User Safety

The researcher should balance two important objectives:

Public Interest	User Safety
Share new security knowledge	Prevent exploitation

Public Interest	User Safety
Improve future research	Allow vendors to patch
Help security professionals	Protect users
Encourage better software design	Avoid releasing weaponized details

Best Balance

Do not hide the research permanently.

Instead:

Notify → Coordinate → Remediate → Peer Review → Anonymize → Publish Safely

This approach provides academic value while reducing the possibility of immediate misuse.

8. Critical Thinking

A difficult situation may occur if a vendor does not respond.

The researcher should:

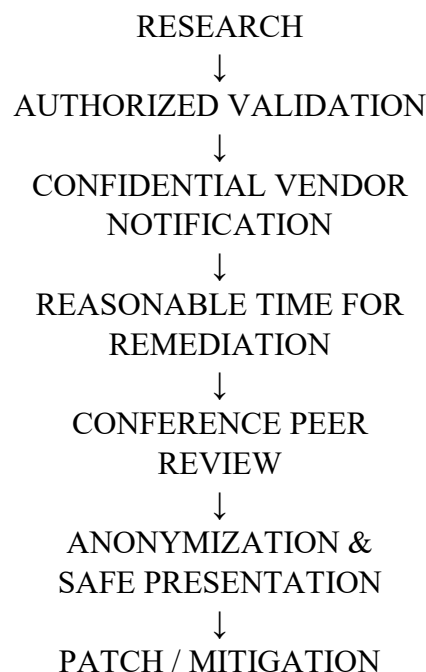
1. Attempt communication through the vendor's official security channels.
2. Keep records of notification attempts.
3. Contact an appropriate coordinating security organization if necessary.
4. Avoid immediately releasing a complete working exploit.
5. Consider the actual risk to users before publication.
6. Discuss delayed or partial disclosure with the conference.
7. Publish defensive information when appropriate.

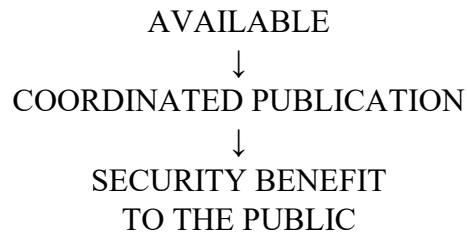
Similarly, **remediation time should not automatically mean an unlimited delay**. The researcher should consider the severity of the vulnerability, vendor responsiveness, availability of mitigations, likelihood of exploitation, and public safety.

9. Final Recommended Course of Action

The researcher should **not immediately publish the complete attack technique** because the affected systems are widely used and patches are unavailable.

The most responsible approach is:





Conclusion

Responsible disclosure protects both **scientific progress and public safety**. The researcher should maintain confidentiality while vendors investigate and remediate the vulnerability, cooperate with the academic conference during peer review, remove sensitive information, and publish the findings only through a coordinated process. This demonstrates **authorization, confidentiality, privacy, professional responsibility, and ethical security research**.